TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

GitLab max-severity RCE exploited; CISA adds it to KEV

From **Cybersecurity Briefing - 2026-10-30** · 2026-10-29 to 2026-10-30 (last 24 hours; Indianapolis and State of Indiana swept back to 2026-10-25) · Briefing generated 2026-10-30

REPORT ID	VERSION	HANDLING
CTI-20261030-01	1.0 · 2026-10-30 09:37 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-12	2026-10-30
CVES	**ANALYST**	
CVE-2026-97229 (CVSS 10.0)	Nick Sturgeon	

VULNERABILITY · CRITICAL · ACTIVELY EXPLOITED · OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CVE-2026-97229 is a CVSS 10.0 flaw in self-managed GitLab Community and Enterprise Edition. A crafted regular expression placed in a CI/CD configuration triggers an integer overflow when the pattern is compiled, which can lead to arbitrary code execution on the GitLab server [S5] [S7]. The bug sits in Onigmo, the regex engine built into Ruby, not in GitLab code itself [S8] [S9]. GitLab fixed it on 2026-10-12 in 19.2.8, 19.3.5 and 19.4.2 [S5]. CISA added it to the Known Exploited Vulnerabilities catalog on 2026-10-29 with a federal due date of 2026-11-01, and its KEV note warns that the same Ruby/Onigmo overflow may affect other products [S3] [S4].

The only public exploitation account comes from Alpine Linux. A newly registered account on Alpine's GitLab sent crafted CI configurations on 2026-10-20 and 2026-10-21, crashing GitLab worker processes eight times, four of them partway through the exploit chain. The attacker also downloaded Alpine's GitLab container image, which Alpine reads as tuning the exploit to its exact build. Further attempts on 2026-10-25 and 2026-10-26 failed [S8] [S10]. Alpine found no proof of code execution but could not rule it out: a successful run leaves no crash and no web-log trace, some attack-day logs were lost, and outbound connections were not logged. Alpine rebuilt the server, reset all passwords, replaced GitLab secret keys, and checked its aports repository, packages and October 21 releases against records outside GitLab. It found no tampering [S8] [S2]. Rapid7 published a working proof of concept on 2026-10-13, one day after the patch [S12] [S10].

The key point for defenders is that upgrading GitLab alone does not fix every install. GitLab's Omnibus packages and official images ship a patched Ruby. Self-compiled installs and custom images that use a stock Ruby stay vulnerable until Ruby itself is upgraded to 3.3.13, 3.4.12, 4.0.9 or later. Those Ruby releases came out on 2026-10-23 [S8] [S9] [S10]. Alpine was still vulnerable after moving to GitLab 19.3.6 for exactly this reason [S8]. A second CVSS 10.0 Onigmo flaw, CVE-2026-110264, reaches back to GitLab 7.0 and was fixed on 2026-10-21 in 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10 and 18.11.13 [S6]. Rapid7's demonstrated route needs write access to a public

project, though the final CI lint request is unauthenticated. Instances that allow open self-registration and project creation are therefore the most exposed [S13] [S12].

What to do: move every self-managed GitLab to the latest patch release on its branch (at least 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10 or 18.11.13). Confirm the Ruby runtime is 3.3.13, 3.4.12, 4.0.9 or later wherever GitLab does not bundle its own Ruby. Turn off open sign-up and anonymous access to public projects. Then hunt for long-running CI lint requests that end in HTTP 502, Puma worker crashes, and shell processes spawned by Puma or Sidekiq as the git user. If anything looks wrong, treat the instance as compromised and rotate gitlab-secrets.json, CI/CD variables, runner tokens and access tokens [S10] [S13]. The attacker behind the Alpine attempts is unknown, and no network indicators have been published.

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
Exploitation attempts against internet-facing self-managed GitLab instances will very likely increase over the next 30 days. A public proof of concept exists, CISA has confirmed exploitation, and the EPSS score sits in the 97th percentile. Instances with open self-registration are the most likely targets. [S3] [S4] [S12] [S14]

LIKELY · MODERATE CONFIDENCE
Some organizations that believe they have patched will likely still be exploitable. Self-compiled GitLab installs and custom container images rely on the system Ruby, and GitLab's October patch notes did not tell those users to upgrade Ruby. [S8] [S9] [S10]

LIKELY · MODERATE CONFIDENCE
Successful compromises will likely go undetected at many victims. Successful exploitation leaves no crash and no web-log trace, and few small and mid-size GitLab operators log outbound connections from the GitLab host. [S8] [S13]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is roughly an even chance that other Ruby applications which compile user-supplied regular expressions will be publicly identified as exploitable through the same Onigmo bugs within 90 days, given CISA's note that other products may be affected. [S4] [S9]

INDICATORS OF COMPROMISE

No IP addresses, domains, hashes or attacker account names have been published by Alpine Linux, GitLab, Rapid7 or CISA as of 2026-10-30. The indicators below are request patterns, log artifacts and host paths taken from Rapid7's 2026-10-16 technical analysis, the Alpine incident post (2026-10-28, updated 2026-10-30) and GitLab guidance as reported by The Hacker News. Derived entries are marked and explained.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`GET /api/v4/projects/<project>/ci/lint?content_ref=<ref>`	CI lint API request used as the unauthenticated trigger in Rapid7's demonstrated chain. content_ref selects the commit whose .gitlab-ci.yml is linted. Requests that run for several seconds and end in HTTP 502 are suspicious.	REPORTED	2026-10-16	[S13]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /api/graphql (ciLint mutation/query containing hostile regex)`	GitLab released a detection named for hostile regexps in GraphQL ciLint requests, which implies the GraphQL CI lint path is also a trigger route. The endpoint path is inferred from GitLab's standard GraphQL route.	DERIVED	2026-10-12	[S5] [S10]
other	`badgateway: failed to receive response: EOF`	Workhorse log message on a CI lint request when the Puma worker crashes mid-request. Rapid7 notes the 502 is a normal side effect of the crash, not proof the exploit failed.	REPORTED	2026-10-16	[S13]
filepath	`/var/log/gitlab/gitlab-workhorse/current`	Workhorse log on Omnibus installs where the long-running lint requests and 502/EOF entries show up.	REPORTED	2026-10-16	[S13]
filename	`regexp_matcher.rb`	Source file named in saved Puma worker crash traces linked to the exploit path.	REPORTED	2026-10-16	[S13]
filename	`.gitlab-ci.yml`	CI configuration that carries the crafted regex, usually in rules:exists or rules:changes. Look for quantifier obfuscation, repeated POSIX word classes, and nearby repository paths that contain four-byte UTF-8 characters.	REPORTED	2026-10-16	[S13] [S10]
command	`sh/bash child process of puma or sidekiq running as the git user`	Rapid7's PoC ran OS commands as the git account. GitLab guidance says to look for unexpected child processes of Puma or Sidekiq. A Puma worker growing by about 2 GiB of memory around the same time strengthens the match.	REPORTED	2026-10-16	[S13] [S10]
filepath	`/tmp/* (files owned by the git user)`	GitLab post-exploitation guidance as reported: check /tmp for files owned by the git user.	REPORTED	2026-10-29	[S10]
other	`Changed crontab or ~/.ssh/authorized_keys for the git user`	GitLab guidance as reported: look for crontab or SSH key changes for the git account as persistence.	REPORTED	2026-10-29	[S10]
other	`Ruby crash report referencing Onigmo in a Puma worker`	GitLab's 'Onigmo native worker crash' threat detection looks for Ruby native crash reports pointing to Onigmo. Alpine saw eight such worker crashes during the attack.	REPORTED	2026-10-12	[S5] [S6] [S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`onigmo_native_worker_crash.md`	GitLab Security OSS detection rule file for Onigmo worker crashes. GitLab says its rules live under Detections/platforms/GitLab/Vulnerability Detections/ in its tldr repository.	REPORTED	2026-10-21	[S11] [S6]
other	`Newly registered user account submitting CI configurations shortly after sign-up`	Alpine's attacker registered a fresh account on 2026-10-20 and then sent crafted CI configurations.	REPORTED	2026-10-20	[S8]
other	`alpinelinux/gitlab:19.3.6 image pulled before 2026-10-27 (and older tags)`	Vulnerable image built with a stock Ruby. Only the 19.3.6 tag rebuilt on 2026-10-27 or later contains Ruby 3.3.13.	REPORTED	2026-10-27	[S8]
filepath	`/etc/gitlab/gitlab-secrets.json`	GitLab advises rotating gitlab-secrets.json if compromise is suspected. This is the default Omnibus location, inferred from standard GitLab packaging.	DERIVED		[S10]
http-request	`POST /users (new account sign-up) followed by project creation and push`	Rapid7 says open self-registration and project creation remove the write-access requirement. The sign-up route is inferred from GitLab's standard registration endpoint and is useful for correlating new accounts with later CI lint activity.	DERIVED		[S12] [S13]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker needs to put a crafted .gitlab-ci.yml, plus a repository path with unusual UTF-8 characters, into a public project. On instances with open sign-up, a freshly registered account can do this. The attacker then calls the CI lint function, which in Rapid7's chain is reachable without credentials for public projects. GitLab compiles the regex from the CI rules (exists/changes) with Ruby's Onigmo engine. An obfuscated quantifier slips past GitLab's pattern checks. Ruby then recompiles the pattern for UTF-8, which expands POSIX classes without a size check. A signed-integer overflow in Onigmo's quantifier expansion and a bad jump offset in alternation compilation hand control to attacker-influenced bytes, and a command runs as the git user [S13]. Failed attempts crash the Puma worker and produce HTTP 502s. A successful run may leave no crash at all [S8] [S13]. The Alpine attacker also downloaded the target's container image to tune the

memory layout [S8]. Once running as git, an attacker can reach repositories, CI/CD variables, runner tokens, integration credentials, and possibly the build pipeline [S10].

Threat actor

Unknown (unattributed actor targeting Alpine Linux GitLab)

Attribution confidence: Low · **Motivation:** Unknown. Targeting a Linux distribution's source and build infrastructure is consistent with a software supply-chain objective, but no source states a motive. · **Suspected origin:** Unknown

Alpine describes only a newly registered account that probed on 2026-10-20 to 2026-10-21 and returned on 2026-10-25 to 2026-10-26. No IPs, account name or attribution have been published. CISA's KEV listing does not name an actor, and ransomware use is marked Unknown [S4] [S8].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1592.002 Gather Victim Host Information: Software	The attacker downloaded Alpine's public GitLab container image, most likely to match the exploit to the exact build and memory layout. [S8]	Hard to detect for public images. Watch registry pull logs for unusual pulls of internal GitLab images.
Persistence	T1136 Create Account	A new account was registered on the target GitLab to gain the project write access needed to plant the crafted CI configuration. [S8] [S12]	Alert on new sign-ups that push CI configuration or call CI lint within hours of registration.
Initial Access	T1190 Exploit Public-Facing Application	A crafted regex in .gitlab-ci.yml rules overflows an integer in Onigmo during compilation, triggered through the CI lint API. [S5] [S13]	Workhorse logs showing long CI lint requests that end in 502/EOF, together with Puma worker crashes and traces mentioning regexp_matcher.rb.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	The corrupted regex matcher runs an OS command as the git user from inside the Puma worker. [S13]	EDR or auditd alert on shell, curl or wget processes whose parent is puma, sidekiq or ruby under the git account.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Failed exploit attempts crashed GitLab workers eight times at Alpine, causing 502 errors and failed CI jobs. [S8]	Monitor for repeated Puma worker restarts and bursts of 502s on CI lint routes.
Credential Access	T1552 Unsecured Credentials	Code execution as git would expose CI/CD variables, runner tokens, webhook and integration credentials, 2FA secrets and password hashes held by the instance. Alpine treated all of these as potentially exposed. [S10]	Watch for use of CI tokens or integration credentials from unfamiliar IPs, and rotate them after any suspected compromise.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1110.004 Brute Force: Credential Stuffing	After the rebuild, Alpine saw automated login attempts that used passwords exposed in other breaches. [S2]	Alert on high rates of failed logins and on successful logins from new IPs after failures.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	This is a potential objective, not an observed one. A compromised GitLab that hosts source and CI could be used to change code or builds. Alpine checked its aports, packages and releases and found no tampering. [S8]	Check commits and release artifacts against out-of-band records, and require signed tags and commits.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

GitLab Workhorse: long-running CI lint requests ending in 502 `SPLUNK SPL`

```
index=gitlab sourcetype=gitlab:workhorse (uri="*/ci/lint*" OR uri="/api/graphql*") (status=502 OR "failed to
receive response: EOF")
| eval dur_s=coalesce(duration_ms/1000, duration)
| where dur_s>=2
| stats count min(_time) as first max(_time) as last values(remote_ip) as src values(uri) as uris by host
| convert ctime(first) ctime(last)
```

Field names depend on how Workhorse JSON logs are ingested from /var/log/gitlab/gitlab-workhorse/current. Correlate hits with Puma worker restarts and with the commit named in content_ref.

Shell spawned by GitLab Puma or Sidekiq as git user `SIGMA`

```
title: Shell Spawned By GitLab Puma Or Sidekiq
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  parent:
    ParentImage|endswith:
      - '/ruby'
    ParentCommandLine|contains:
      - 'puma'
      - 'sidekiq'
  child:
    Image|endswith:
      - '/sh'
      - '/bash'
      - '/dash'
      - '/curl'
      - '/wget'
      - '/python3'
      - '/perl'
      - '/nc'
  user:
    User: 'git'
  condition: parent and child and user
falsepositives:
  - Legitimate GitLab maintenance tasks that shell out (git hooks, rake tasks); baseline first
level: high
```

Needs auditd or an EDR that records parent command lines. GitLab legitimately runs git subprocesses, which is why git itself is not in the child list.

Puma worker crash referencing Onigmo or regexp_matcher.rb `SPLUNK SPL`

```
index=gitlab (sourcetype=gitlab:puma OR sourcetype=gitlab:puma_stderr OR sourcetype=gitlab:rails)
("onigmo" OR "regexp_matcher.rb" OR "[BUG] Segmentation fault" OR "worker terminated" OR "Worker timed out")
| stats count values(_raw) as samples by host
| where count>=1
```

Based on GitLab's 'Onigmo native worker crash' detection theme and Rapid7's crash artifacts. Tune the strings to your log format. GitLab's official rules are in its Security OSS tldr repository.

Inbound CI lint API calls to GitLab (cleartext or TLS-inspected) `SURICATA`

```
alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"GitLab CI lint API request with content_ref (CVE-2026-97229
trigger path)"; flow:established,to_server; http.method; content:"GET"; http.uri; content:"/api/v4/projects/";
startswith; content:"/ci/lint"; distance:0; content:"content_ref="; distance:0; classtype:web-application-
attack; sid:9726229; rev:1;)
```

Only fires where TLS is terminated before the sensor. Legitimate CI lint use is common, so treat this as a hunting signal and correlate with 502 responses and worker crashes.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
GitLab CE/EE (self-managed)	19.2 before 19.2.8; 19.3 before 19.3.5 (19.3.4 is now listed as affected); 19.4 before 19.4.2	19.2.8, 19.3.5, 19.4.2 (latest Oct 21 releases 19.2.9, 19.3.6, 19.4.3 also fix CVE-2026-110264)	CVE-2026-97229	10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)	0.18427 (97.2nd percentile, 2026-10-29)	Yes (added 2026-10-29)	2026-11-01
GitLab CE/EE (self-managed), related Onigmo flaw	7.0 before 18.11.13; 19.0 before 19.0.10; 19.1 before 19.1.9; 19.2 before 19.2.9; 19.3 before 19.3.6; 19.4 before 19.4.3; 19.5 before 19.5.1	18.11.13, 19.0.10, 19.1.9, 19.2.9, 19.3.6, 19.4.3, 19.5.1	CVE-2026-110264	10.0	Not retrieved	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Ruby (Onigmo regex engine) used by self-compiled GitLab, custom images, and other Ruby apps compiling untrusted regexes	Ruby 3.3 before 3.3.13; 3.4 before 3.4.12; 4.0 before 4.0.9; Ruby 3.2 and earlier (EOL, no fix)	3.3.13, 3.4.12, 4.0.9	CVE-2026-97229, CVE-2026-93577, CVE-2026-89078, CVE-2026-110264 (GitLab-assigned)	See GitLab CVEs	N/A	Yes (via CVE-2026-97229, added 2026-10-29)	2026-11-01

Immediate (0–24 hours)

- Inventory every self-managed GitLab instance, including lab, dev and client-hosted servers. Record the GitLab version, install method (Omnibus package, official image, self-compiled or custom image) and Ruby version (run ruby -v as the GitLab runtime user). `IT OPS` [S5] [S8]
- Upgrade GitLab to the latest patch release on its branch (19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10 or 18.11.13 or later). This covers both CVE-2026-97229 and CVE-2026-110264. Servers on 19.3.4 are not fixed. `IT OPS` [S5] [S6] [S10]
- On self-compiled installs and custom images, also upgrade Ruby to 3.3.13, 3.4.12, 4.0.9 or later, then restart Puma and Sidekiq. Move Ruby 3.2 hosts to a supported series. On Alpine, run apk upgrade. Users of the alpinelinux/gitlab image should pull the 19.3.6 tag rebuilt on 2026-10-27 or later. `IT OPS` [S8] [S9]
- Until patching is verified, disable open sign-up, block anonymous access to public projects, restrict project creation to trusted users, and consider blocking the CI lint routes at the reverse proxy. These steps reduce exposure but do not fix the bug. `IT OPS` [S12] [S13]
- Hunt back to 2026-10-12: CI lint requests that end in 502/EOF, Puma worker crashes mentioning Onigmo or regexp_matcher.rb, shells spawned by Puma or Sidekiq, git-owned files in /tmp, and crontab or SSH key changes for

the git user. SOC [S10] [S13]

Short term (1–7 days)

- If any hunt hit is unexplained, treat the instance as compromised. Rebuild from known-good media, and rotate gitlab-secrets.json, all CI/CD variables, runner registration and authentication tokens, personal and project access tokens, deploy keys, and webhook and integration credentials. SOC [S8] [S10]
- Deploy GitLab's published threat detections (including 'Onigmo native worker crash' and the CI lint and regexp guard rules) from the GitLab Security OSS repository into the SIEM. SOC [S5] [S6] [S11]
- Review accounts created since 2026-10-12, especially any that created projects or pushed .gitlab-ci.yml soon after sign-up. Force password resets for any suspicious accounts and enable MFA for all users. SOC [S8] [S2]
- Find other internal Ruby applications that build regexes from user input (Regexp.new, Regexp.union, Regexp.compile, or interpolation) and upgrade their Ruby runtime. Regexp.timeout does not protect against these bugs. IT OPS [S9] [S4]
- Verify recent commits, tags and release artifacts against out-of-band copies such as developer clones and build-server records. IT OPS [S8]

Long term

- Set a policy to apply critical GitLab security releases within 24 hours. For each release, check for Ruby or other component patches that non-Omnibus builds must apply separately. LEADERSHIP [S8]
- Log outbound and database connections from source-code and CI servers, and keep GitLab logs longer than 14 days. IT OPS [S8]
- Require signed commits and signed release tags. Keep signing keys off the GitLab server so releases can be verified independently. IT OPS [S8]
- Prefer GitLab's official packages or images, which bundle a patched Ruby, over self-compiled or custom images unless there is a documented reason. LEADERSHIP [S8] [S10]

Workarounds & compensating controls

- Put self-managed GitLab behind VPN or zero-trust access rather than exposing it directly to the internet. IT OPS [S12]
- Block or tightly rate-limit /api/v4/projects/*/ci/lint and GraphQL ciLint requests from unauthenticated or untrusted sources at the WAF or reverse proxy. IT OPS [S13]
- Restrict outbound network access from the GitLab host to required destinations only, which limits post-exploitation callbacks and data theft. IT OPS [S8]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: CISA Adds Actively Exploited GitLab RCE and Cisco Firewall DoS Flaws to KEV
Published 2026-10-30 · B1 Usually reliable, confirmed by other sources
Briefing source. KEV addition and Alpine summary.

[S2] SecurityWeek: Max-Severity GitLab Vulnerability Exploited Against Alpine Linux
Published 2026-10-30 · **B1** Usually reliable, confirmed by other sources
Briefing source. Ruby caveat; reports credential-stuffing attempts after Alpine's rebuild.

[S3] CISA: CISA Adds Two Known Exploited Vulnerabilities to Catalog
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary source. KEV alert.

[S4] CISA: Known Exploited Vulnerabilities Catalog (JSON feed), entry CVE-2026-97229
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary source. dateAdded 2026-10-29, dueDate 2026-11-01, ransomware use Unknown; note says other products may share the Ruby/Onigmo flaw.

[S5] GitLab: Patch Release: 19.4.2, 19.3.5, 19.2.8
Published 2026-10-12 · **A1** Completely reliable, confirmed by other sources
Vendor advisory. Affected and fixed versions, CVSS vector, credit to joaxcar, six threat detections.

[S6] GitLab: Patch Release: 19.5.1 (and backports) - CVE-2026-110264
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
Vendor advisory for the related Onigmo flaw. Location of detection rules.

[S7] MITRE / CVE Program: CVE-2026-97229 record
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
CNA GitLab. CWE-190; CISA ADP shows KEV on 2026-10-29.

[S8] Alpine Linux: GitLab security incident: attempted exploitation of CVE-2026-97229
Published 2026-10-28 · **A2** Completely reliable, probably true
Victim's own account. Timeline, versions, response steps. The page is internally inconsistent about reopening status.

[S9] Ruby: Regexp fixes for GitLab CVEs
Published 2026-10-23 · **A1** Completely reliable, confirmed by other sources
Upstream advisory. Maps four GitLab CVEs to Onigmo fixes; fixed Ruby 3.3.13, 3.4.12, 4.0.9.

[S10] The Hacker News: Attacker Tried to Exploit Alpine Linux's GitLab via CVSS 10.0 Flaw Its Ruby Left Open
Published 2026-10-29 · **B2** Usually reliable, probably true
Detailed analysis. Version table, GitLab hunting and rotation guidance, note that 19.3.4 was reclassified as affected.

[S11] The Hacker News: Ruby Fixes Three Regex Engine Bugs Behind Four GitLab RCE Flaws
Published 2026-10-23 · **B2** Usually reliable, probably true
Context on the four GitLab CVEs. Names the onigmo_native_worker_crash.md detection file.

[S12] Rapid7: CVE-2026-97229: Critical Unauthenticated Remote Code Execution in GitLab
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
Researcher emergent threat response, updated 2026-10-30 for KEV. Public PoC exists (not retrieved).

[S13] Rapid7: Rapid7 Analysis: GitLab CI/CD Regex Integer Overflow (CVE-2026-97229)
Published 2026-10-16 · **A2** Completely reliable, probably true
Technical analysis. Attack chain, request pattern, log and crash artifacts. Rapid7 cautions the undisclosed original path may differ.

[S14] FIRST: EPSS API - CVE-2026-97229
Published 2026-10-29 · **A2** Completely reliable, probably true
EPSS 0.18427, percentile 0.97229.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-10-12	GitLab releases 19.4.2, 19.3.5 and 19.2.8 fixing CVE-2026-97229 (CVSS 10.0), with bundled Ruby regexp patches and six threat detections.	[S5]
2026-10-13	CVE record published. Rapid7 publishes an advisory and PoC. Alpine mistakenly upgrades to 19.3.4.	[S7] [S12] [S8]
2026-10-16	Rapid7 publishes its technical analysis of the exploit chain and detection artifacts.	[S13]
2026-10-20	A newly registered account begins probing Alpine's GitLab with crafted CI configurations.	[S8]
2026-10-21	Main attack on Alpine's GitLab: eight worker crashes, 502s and failed CI jobs. GitLab releases fixes for related CVE-2026-110264 across seven branches.	[S8] [S6]
2026-10-22	Alpine upgrades to GitLab 19.3.6 but stays vulnerable because its image uses a stock Ruby.	[S8]
2026-10-23	Ruby releases 3.3.13, 3.4.12 and 4.0.9 with the Onigmo fixes. Alpine blocks the attacker's account.	[S9] [S8]
2026-10-25	The attacker returns (2026-10-25 to 2026-10-26) and attempts fail.	[S8]
2026-10-27	Alpine restricts GitLab access and begins a rebuild. A fixed alpinelinux/gitlab:19.3.6 image with Ruby 3.3.13 is published.	[S8]
2026-10-28	Alpine finishes the rebuild, resets passwords, replaces secret keys, and publishes its incident post.	[S8] [S10]
2026-10-29	CISA adds CVE-2026-97229 to KEV with a due date of 2026-11-01.	[S3] [S4]

Date	Event	Source
2026-10-30	Rapid7 updates its advisory for the KEV listing. Alpine reports GitLab reopened.	[S12] [S8]

Relevance to Indianapolis, Indiana & managed clients

Self-managed GitLab is common in Indiana among software and engineering teams at manufacturers and logistics firms, at universities and research groups (where open self-registration is often enabled for students and collaborators), in state and local government IT shops, and at healthcare organizations that build internal apps. Managed IT clients are exposed in three ways. Some run GitLab on a VM that was set up once and rarely patched. Some use a community or custom Docker image whose Ruby is not updated by a GitLab upgrade. Some keep GitLab internet-facing for remote developers. CI/CD variables on these servers often hold cloud keys, database passwords and deployment credentials, so a GitLab compromise can lead to production systems and, for software vendors, to downstream customers. Indiana public-sector bodies that follow CISA guidance should treat the 2026-11-01 KEV date as their target. Service providers should check every client environment for GitLab and confirm both the GitLab and Ruby versions, not just the GitLab version, before closing the ticket. No Indiana-specific targeting has been reported.

Intelligence gaps

- Identity, infrastructure and motive of the actor behind the Alpine attempts. No IPs or account details have been published.
- Which exploitation CISA relied on for the KEV listing, and whether victims other than Alpine exist.
- Whether any exploitation has succeeded anywhere. Alpine cannot rule it out because of missing logs.
- How the original reported attack path achieves the PR:N rating without project write access. Rapid7 could not reproduce a fully unauthenticated route.
- How many self-managed instances are internet-exposed and running vulnerable GitLab or Ruby. No exposure figure was confirmed from a primary source.
- Whether other Ruby applications that compile untrusted regexes are exploitable in practice, as CISA's KEV note suggests.
- Whether GitLab will update its self-compiled install guidance (which still listed Ruby 3.2 as the minimum) to require patched Ruby versions.

Other notes

- The briefing excerpt said fixed versions were not confirmed from the GitLab advisory. They are now confirmed from GitLab's 19.4.2 release post: 19.2.8, 19.3.5 and 19.4.2 [S5]. GitLab originally named 19.3.4 as fixed and later reclassified it as affected [S10].
- Earlier coverage (S11 on 2026-10-23, S10 as of the 2026-10-28 KEV update) said the CVE was not in KEV. That reflects timing, not a conflict: CISA added it on 2026-10-29.
- SecurityWeek and the KEV entry cite a three-day federal deadline under BOD 26-04 [S2] [S4].
- The CWE-190 label fits the Onigmo signed-integer overflow described by Rapid7 and Ruby, even though GitLab's text describes the cause as insufficient regex validation [S7] [S9] [S13].
- Related GitLab-assigned Onigmo CVEs: CVE-2026-89078 (double free), CVE-2026-93577 (pattern size overflow), CVE-2026-110264 (repeat ID overflow, CVSS 10.0) [S9] [S6]. Ruby had not requested its own CVE IDs [S9].
- The same GitLab KEV alert also added Cisco ASA/FTD CVE-2026-76418 (CVSS 8.6 DoS). That flaw is out of scope here [S1] [S3].

CTI-20261030-01 v1.0 · Generated 2026-10-30 09:37 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.